



AMERICAN
UNIVERSITY
OF BEIRUT

Module 5 Additional Readings

Security, Governance, Advanced Workflows & Looking Ahead

How Students Should Use This Resource

- Read the Core readings after the lecture. These are the minimum supporting readings for Module 5.
- Use the Practical references while completing the Codex App setup, AGENTS.md, security review, governance worksheet, comments-feature plan, architecture document, and AI playbook.
- Use Optional deeper dives only if you want more detail. They are not required for the quiz or deliverables.
- Read selectively. The “Read / use this part” line tells you which section matters for the module, so you do not have to read a whole standard or long research paper.

Core Readings:

Recommended time: about 55–70 minutes total if students focus only on the listed sections. These readings directly support the Module 5 videos and deliverables.

Core 1. OpenAI — Codex app

Link: [OpenAI — Codex app](#)

Purpose: Use this as the official reference for the desktop app surface taught in Module 5: selecting a project folder, using threads, and working from the actual repository instead of a generic chat.

Read / use this part: Focus on the overview of the Codex app as a command center, project threads, worktrees, and Git functionality. Skip CLI, IDE extension, automations, and advanced integrations for this module.

Core 2. OpenAI — Custom instructions with AGENTS.md

Link: [OpenAI — Custom instructions with AGENTS.md](#)

Purpose: Use this to understand why Module 5 creates AGENTS.md before asking Codex to review, plan, or document the repo.

Read / use this part: Focus on what AGENTS.md is, how Codex reads it, and what belongs in project guidance: stack, commands, testing expectations, security notes, and path boundaries.

Core 3. OpenSSF — Security-Focused Guide for AI Code Assistant Instructions

Link: [OpenSSF — Security-Focused Guide for AI Code Assistant Instructions](#)

Purpose: Use this to reinforce the Module 5 security posture: AI can assist, but the developer remains responsible for reviewing and editing generated code.

Read / use this part: Read the opening principles and the guidance on security-focused instructions. Use it as a companion to the security review, governance retrospective, and personal AI usage rules.

Core 4. OWASP — Secure Code Review Cheat Sheet

Link: [OWASP — Secure Code Review Cheat Sheet](#)

Purpose: Use this to support the manual scan after Codex produces a security audit. It gives students concrete lenses beyond generic “is this secure?” thinking.

Read / use this part: Focus on security-focused review, input validation, authentication, authorization, error handling, logging, data exposure, and attack vectors. Translate the checklist into Task Tracker questions.

Core 5. Martin Fowler / Thoughtworks — Context Engineering for Coding Agents

Link: [Martin Fowler / Thoughtworks — Context Engineering for Coding Agents](#)

Purpose: Use this as the most directly relevant practitioner reading for the context engineering activity.

Read / use this part: Focus on context engineering for coding agents, reusable instructions, files as context, and why keeping context focused matters. Skip tool-specific details unless useful for comparison.

Practical References: Use These While Working

These are not required sit-and-read assignments. Keep them open while completing the Module 5 deliverables or when you need a quick check.

Practical 1. OpenAI — Codex app review pane

Link: [OpenAI — Codex app review pane](#)

Purpose: Use this while inspecting diffs and deciding what to keep, reject, or comment on in the Codex App.

Read / use this part: Focus on what the review pane shows and how it helps you understand changes, give targeted feedback, and decide what to keep.

Practical 2. OpenAI — Codex app settings

Link: [OpenAI — Codex app settings](#)

Purpose: Use when configuring the Codex App environment, editor/file behavior, and local workflow preferences.

Read / use this part: Use only the settings that help you complete the module safely. Do not spend time optimizing the app before completing the docs-first deliverables.

Practical 3. AGENTS.md — Open format guide

Link: [AGENTS.md — Open format guide](#)

Purpose: Use this for examples of what belongs in an agent-facing project guidance file: overview, setup commands, testing commands, code style, and security considerations.

Read / use this part: Copy the structure, not the content. Your Module 5 AGENTS.md should reflect the Task Tracker stack and the module boundaries: read first, docs-first, and reject unexpected app/ edits.

Practical 4. OWASP — Top Ten Web Application Security Risks

Link: [OWASP — Top Ten Web Application Security Risks](#)

Purpose: Use while grading Codex security findings and writing the top-3 backlog.

Read / use this part: Focus on categories likely to appear in a small web app: broken access control, injection, insecure design, security misconfiguration, vulnerable/outdated components, and logging/monitoring gaps.

Practical 5. GitHub Docs — Responsible use of GitHub Copilot code review

Link: [GitHub Docs — Responsible use of GitHub Copilot code review](#)

Purpose: Use this as a cross-tool reminder that AI review is a supplement to human review, not a replacement for it.

Read / use this part: Focus on capabilities, limitations, false positives, missed issues, and how to improve review quality. Skip product setup.

Practical 6. GitHub Docs — Best practices for using GitHub Copilot

Link: [GitHub Docs — Best practices for using GitHub Copilot](#)

Purpose: Use this for transferable context habits: provide helpful context, keep relevant files visible, and start a new conversation when context becomes unhelpful.

Read / use this part: Focus on context-management advice. Skip Copilot-specific setup unless you use Copilot outside this course.

Optional Deeper Dives: For Students Who Want More Detail

These readings are useful, but they are not necessary for completing Module 5. Use them only after the core readings and practical references.

Optional 1. Anthropic Engineering — Effective context engineering for AI agents

Link: [Anthropic Engineering — Effective context engineering for AI agents](#)

Purpose: Use this if you want a broader agent-engineering explanation of why context quality affects agent behavior.

Read / use this part: Read the introduction and the definition of context engineering. Skip advanced agent orchestration details unless you are building agent systems yourself.

Optional 2. LangChain — Context Engineering for Agents

Link: [LangChain — Context Engineering for Agents](#)

Purpose: Use this if you want a compact vocabulary for context strategies beyond Module 5.

Read / use this part: Focus on the write, select, compress, and isolate categories. Map them back to Module 5 strategies A, B, and C rather than treating them as new required terms.

Optional 3. NIST — AI RMF Playbook

Link: [NIST — AI RMF Playbook](#)

Purpose: Use this if you want to connect your personal governance rules to a broader risk-management framework.

Read / use this part: Skim the Govern, Map, Measure, and Manage framing. Do not try to apply the whole framework to the Task Tracker project.

Optional 4. NIST — Generative AI Profile for the AI RMF

Link: [NIST — Generative AI Profile for the AI RMF](#)

Purpose: Use this if you want to see how a formal risk framework is extended for generative AI systems.

Read / use this part: Read selectively for governance language around generative AI risk. Skip detailed crosswalks and enterprise controls unless needed for a workplace context.

Optional 5. Research papers on AI-generated code security

Link: [arXiv — Security Vulnerabilities in AI-Generated Code: A Large-Scale Analysis](#)

Companion link(s): [Frontiers in Big Data — SLR on AI models and code-generation security](#) | [arXiv — Security Weaknesses of Copilot-Generated Code in GitHub Projects](#)

Purpose: Use for instructors or advanced students who want evidence behind the claim that AI-generated code still needs security review.

Read / use this part: Suggested order: skim the large-scale GitHub analysis abstract, then the systematic literature review, then the Copilot-generated-code empirical study if you want more depth.